PENSION BENEFIT MANAGEMENT
AUDIT PROGRAM #40-70-00

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events in order to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
March 18, 2026	Process and Objective	Enterprise Risk Management	Joana Leal	Included the updated Enterprise Risk Management
January 6, 2025	Process and Objective	Enterprise Risk Management	Joana Leal	Included the updated Enterprise Risk Management
January 6, 2025	Process and Objective	Reference Material	Joana Leal	Updated links
April 12, 2023	Control Assessment Question	Defined Risk Area Control - Assessment Question #6	Jacob Nyamwega	Changed defined risk area and control assessment question #6 to Access Management and Data Protection (from Cybersecurity and Data Protection)
April 2023	Cybersecurity & Data Protection	CP001.P	Don Dobrzelewski	Added Privacy Testing
February 2023	All	All	CA&AS	Converted from Notes into a Word document and into a Box folder

Table of Contents

PROCESS AND OBJECTIVE

Process

For the purpose of this internal audit program, Pension benefit management encompasses processes which relate to the liability an employer has to its employees for Defined Benefit and Defined Contribution. The key responsibilities include: plan benefit calculations, benefit payments, vendor management, employee and matching contributions, beneficiary eligibility, fees and contract administration, administrator's responsibilities, and employee account valuations.

Pension Plans are split into two separate auditable units, pension asset management and pension benefit management. This audit program is for use in a pension benefit management audit and relates to an audit of the Defined Benefit and Defined Contribution management, payment of retirees, and overall retirement benefits process.

While similarities exist between the Pension Benefit and Pension Asset processes, the test for Pension Benefit management should be geared to address the risk related to the Benefit (HR) side of the pension plan.

Objective

- To ensure employee pension payments are calculated and executed according to plan documents.
- To ensure required employee and employer contributions are calculated and executed according to plan documents.
- To verify Human Resources (HR) assumptions associated with net periodic pension cost (NPPC) have been accurately and appropriately communicated to the actuary. Applicable to DB only.
- To ensure the integrity of individual employee records and that personally identifiable information is adequately protected.
- To validate that beneficiary eligibility is managed and ensures that only eligible participants are paid, as well as ensures all entitled beneficiaries receive benefits.
- To validate there is sufficient focus on account reconciliations, contract management, and separation of duties in both in-house and outsourced situations.
- To ensure that individual participant accounts are valued at the correct unit and asset level.

Enterprise Risk Management:

IBM Business Risks
AI differentiation, leadership, and monetization
Market preference for IBM hybrid multi-cloud offerings and as-a-service offerings
Ecosystem and new client adoption of IBM technologies
AI disruption to consulting delivery
Transformation speed and achievement of productivity objectives
Capital allocation strategy effectiveness
Hiring top talent, workforce re-skilling and flexibility

Market Risks
Cybersecurity threats
Geopolitical tensions and trade policies
Government and industry regulations
Reputational harm
Resiliency for business interruptions
Shifting Economic and financial conditions
Supply chain vulnerability

Not all of these risks are captured by or relate to every process within IBM. The intent is to provide a general guide on which ERM risks generally relate to this process (risk in blue font).

PLANNING: Audit Program Risk Alignment

Pension Benefit Management

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Benefit Calculation, Payment, and Contribution	High	Cash Controls	CC002.P, CC002.P, CC005.P
Access Management and Data Protection	High	Cybersecurity and Data Protection	CP001.P
Participant Asset Valuations (only applicable for DC)	Medium	Cash Controls	CC004.P
Vendor Management	Medium	Fees and Contract Administration	FC002.S
Separation of Duties	Medium	Separation of Duties and Authorizations	SD001.P
Account and Payment Reconciliations	Medium	Cash Controls	CC001.P
Plan Participation and Eligibility	Medium	Cash Controls	CC002.P, CC003.P
Human Resources Net Periodic Pension Costs (only applicable for DB)	Low	Net Periodic Pension Cost Assumptions	HR001.P
Fees and Expenses	Low	Fees and Contract Administration	FC001.P

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Technology team.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

The Data Analysis engagement procedures in the Audit Manual (link internal to CA&AS members only) provide further suggestions.

This table shows what data can be reviewed and analysis techniques.

Data to be Analyzed	Analysis to be Performed	Possible Anomalies	Concern
Participant Asset Valuation (only applicable for DC)	Is the asset value at participant level correct based on the selections made by participant Does the sum of participant accounts equal the total fund valuation	For DC - contributions at a participant level made by IBM or employee are accurate based on selections Incorrect number of units or unit price applied to purchased units	Participants might have incorrect asset values within their funds Fund or participant valuations may be inaccurate
Pension plan details	Understand the design of all plans and the regulations within the country governing all plans	Inconsistencies with the plan design and government regulations	Could create increase financial liability for IBM
Retirement Decision Process	Education, eligibility, and data integrity	Information sent with SPI information properly protected Are all participants accurately reflected throughout the process and receiving the accurate payments	Inadequate data protection, incorrect participants, incorrect pension calculations, incorrect payments
Active benefit payees and beneficiaries (DB), where applicable	Sort by relevant benefit plan service reference dates	Validate eligible participants received their entitled pension benefits	Eligible beneficiary may not have received their entitled pension benefit.
Deferred participants not yet in pay status (DB), where applicable	Sort by name, payment, and employee ID	Check for potential duplicate payees or payees who are not eligible	Employee may have been set up twice or receiving payments they are not entitled to

PLANNING: Data Analysis (Continued)

Data to be Analyzed	**Analysis to be Performed**	**Possible Anomalies**	**Concern**
Fees paid if outsourced	Trending	Duplicate fees or noticeable fee increases or decreases	Agreed to contract terms may have been violated
DC contributions vs 401(k)	Plan changes that would have led to logic updates	All pay periods not included in system change Payroll manual adjustments not captured in payroll cycle Accumulators to track year end 401(k) contributions not updated	Incorrect employer contributions made to participants (overpayments or underpayments)
Automatic and Matching Contributions	Trending (within participant universe)	See points below for anomalies	Incorrect employer contributions made to participants (overpayments or underpayments)
Actuarial Information	Trending	Sharp increases or decreases in the employee information required for actuarial calculations	Information provided to actuaries is not accurate

<u>Pension Benefit Management Specific Guidance</u>
The following information is the type that would be beneficial for using queries during this audit:

- A list of all benefit related cash transactions which have taken place within and outside of the fund for each bank for a specified period (usually a six-month time frame).
- A list of all Vendor fees and expenses which have taken place within and outside of the fund for full prior year and year-to-date current year.
- A list of all pension fund payments made to retirees and other employees for a specified period.

- A list of all pension fund employee and employer contributions made eligible participants and matching IBM contributions over a specified period.
- Within the universe of participants for the plan, work with the data analytics team to perform data analysis to include different scenarios based on the universe. For a defined contribution audit these scenarios could include the following:

    - Look at hire dates to ensure participants are in the correct plan.

    - Look at participants that have more or less semi-monthly/monthly payments than the regular amount of pay cycles and review why contributions would be made out of cycle or more than one in a pay period.

PLANNING: Data Analysis (Continued)

- Based on eligibility guidelines if the participants were supposed to get automatic or matching contributions from the company, look at those who did not contribute, but have a match/auto contribution.

- Look at participants that are receiving matching IBM contributions, however, are not making participant contributions.

- Look at negative contributions made to employee accounts and see if those were corrections executed accurately.

- Look at status and plan codes to validate appropriate actions have been taken for participants in those plans/situations.

- In countries where employee participation is required, match employee hire date records with when contributions started.

- Look at employee who went on disability to validate auto and match contributions were accurate for their account.

PLANNING: Reference Material

US/CHQ/EMEA/AP and LA

- FIN 175 - IBM Retirement funds investment management
  IBM Corporate Documents - FIN 175

- Accounting Practices and interpretation – Pensions
  Accounting Policy & Financial Reporting - Accounting Practices & Interpretations (ibm.com)

- Accounting Controls See Standard for Reconciliations of Balance Sheet Accounts
  AI CTRL 12-005 - Standard for Reconciliations of Balance Sheet Accounts.docx | Powered by Box)

- General Data Protection Regulation (GDPR):
  Privacy@IBM - GDPR

- IBM Data Privacy Policy
  Corporate Policy 130 - IBM Data privacy policy (IBM Corporate Documents - CP 130)

- Pension Asset Policy documents
  IBM Retirement Funds Pension Management - Policy Documents

- IBM Procurement Blue Book
  Global Policies & Practices Blue Book

Glossary

ABO - Accumulated Benefit Obligation - the present value of benefits earned to date with benefits computed based on current compensation levels.

Active management - Refers to the use of a human element - such as a single manager, co-managers, or a team of managers - to actively manage a fund's portfolio. Active managers rely on analytical research, forecasts and their own judgment and experience in making investment decisions on what securities to buy, hold and sell. The opposite of active management is called passive management, better known as indexing.

Active Participant - an individual who is currently employed and covered by a plan or are earning or retaining credited service under a plan.

Basis Point - A unit that is equal to 1/100th of 1%.

Benchmark - A standard against which the performance of a security, mutual fund or investment manager can be measured.

Buy and Hold - A passive investment strategy in which an investor buys stocks and holds them for a long period of time, regardless of fluctuations in the market. An investor who employs a buy-and-hold strategy actively selects stocks, but once in a position, is not concerned with short-term price movements and technical indicators.

Cash Balance Plan - A pension plan under which an employer credits a participant's account with a set percentage of his or her yearly compensation plus interest charges. A cash balance pension plan is a defined-benefit plan. As such, the plan's funding limits, funding requirements and investment risk are based on defined-benefit requirements: as changes in the portfolio do not affect the final benefits to be received by the participant upon retirement or termination, the company solely bears all ownership of profits and losses in the portfolio.

PLANNING: Reference Material (Continued)

CSA (credit support annex) - A credit support annex provides credit protection by setting forth the rules governing the mutual posting of collateral. CSAs are used in documenting collateral arrangements between two parties that trade privately negotiated (over the counter) derivative securities. The trade is documented under a standard contract called a master agreement, developed by the International Swaps and Derivatives Association (ISDA). The two parties must sign the ISDA master agreement and execute a credit support annex before they trade derivatives with each other.

Defined benefit - An employer-sponsored retirement plan where employee benefits are calculated based on a formula, using factors such as salary history and duration of employment. Investment risk and portfolio management are entirely under the control of the company. There are also restrictions on when and how you can withdraw these funds without penalties. - promise to pay, etc.

Defined contribution - A retirement plan wherein a certain amount or percentage of money is set aside each year by a company for the benefit of the employee. There are restrictions as to when and how you can withdraw these funds without penalties.
Derivatives - In finance, a security whose price is dependent upon or derived from one or more underlying assets. The derivative itself is merely a contract between two or more parties. Its value is determined by fluctuations in the underlying asset. The most common underlying assets include stocks, bonds, commodities, currencies, interest rates and market indexes. Most derivatives are characterized by high leverage.

EAFE - Stock Index tracking the Europe, Australasia, and Far East (EAFE) stock index.

ER - Excess Return.

ERISA - The Employee Retirement Income Security Act of 1974 (ERISA) protects the retirement assets of Americans, by implementing rules that qualified plans must follow to ensure that plan fiduciaries do not misuse plan assets.

EROA - Expected Return On Asset.

GDPR – General Data Protection Regulation. Standardizes data protection law across all 28 European Union countries and imposes strict rules on controlling and processing personally and identifiable information.

Hedge - A means of risk protection against loss due to adverse price fluctuation by buying or selling a futures contract or option to offset a present or anticipated position or transaction in the cash market.

ICDR - Investment Committee Data Report.

Inactive Participant - an individual who is retired or separated from the company and is covered by a plan and is receiving or is entitled to receive benefits.

Index - A statistical measure of change in an economy or a securities market. In the case of financial markets, an index is an imaginary portfolio of securities representing a particular market or a portion of it. Each index has its own calculation methodology and is usually expressed in terms of a change from a base value. Thus, the percentage change is more important than the actual numeric value.

PLANNING: Reference Material (Continued)

IR - Information Ratio.

ISDA Master Agreement - The ISDA (International Swap Dealer's Association) master agreement contains the terms, conditions and responsibilities surrounding all swap arrangements executed between two parties.

Manager of managers - an investment fund that uses an investment strategy of directly selecting different investment managers and gives them mandate to make investment decisions.

OPEB - Other Post-Employment Benefits.

Passive Management - An investing strategy that mirrors a market index and does not attempt to beat the market.

PBO - Projected Benefit Obligation - The ABO increased to reflect expected future compensation.

Pension Shortfall - A situation in which a company offering employees a defined benefit plan does not have enough money set aside to meet the pension obligations to employees who will be retired in the future.

Pooled Fund- Funds from many individual investors that are aggregated for the purposes of investment, as in the case of a mutual or pension fund. Investors in pooled fund investments benefit from economies of scale, which allow for lower trading costs per dollar of investment, diversification and professional money management.

Rebalancing - The process of buying and selling investments to bring them back within the approved strategy weights.

REITS - Real Estate Investment Trust.

STRIPS - An acronym for 'separate trading of registered interest and principal securities'. Treasury STRIPS are fixed-income securities sold at a significant discount to face value and offer no interest payments because they mature at par.

TIPS - Treasury Inflation Protected Securities - A special type of Treasury note or bond that offers protection from inflation. Like other Treasuries, an inflation-indexed security pays interest every six months and pays the principal when the security matures. The difference is that the coupon payments and underlying principal are automatically increased to compensate for inflation as measured by the consumer price index (CPI). Also referred to as "Treasury inflation-indexed securities".

Tracking Error (TE) - A divergence between the price behavior of a position or a portfolio and the price behavior of a benchmark. This is often in the context of a hedge that did not work as effectively as intended, creating an unexpected profit or loss instead.

Yield - The return on investment that an investor receives from dividends or interest expressed as a percentage of the current market price of the security or, if the investor already owns the security, of the price paid. The return on stocks is usually computed by dividing the total dividends paid in the past calendar year by the price of the stock. The truth in bonds is computed by dividing the interests by the price of the bond.

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and resulting in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
Invalid Contribution and Benefit Payments Inaccurate participant asset valuations	1. Payment Controls 2. System Access Controls 3. Participant level account reconciliations and valuations	Determine how payments are being made and valuations determined, including through IBM payroll system or through a vendor. For manual payments: • Ensure the eligibility of a pensioner recipient and years of service calculation is accurately performed taking in consideration interest. • Verify that the pensioner is an actual employee of the company with correct identification information • Verify that a reconciliation is being performed to tie out the benefit payment to what payment is actually made to the participant, beneficiary, or alternate payee • If employee was part of a divestiture should their benefit continue or was it transferred to the new company?

PLANNING: Fraud Template (Continued)

Description of Fraud Risk	Typical Controls that should Detect the Fraud Risk	Testing Approach
		For System Generated payments: • The participant, beneficiary, or alternate payee • is the appropriate person to be receiving the payment. • Benefit payment calculation is accurate based on years of service and interest. • Manually recalculate what the payment should be to verify system accuracy. • Contribution payment calculation is accurate based on any changes made to employee account. • Automatic and Matching contributions are processed according to IBM plan guidelines. • Ensure participant accounts are valued properly, including number of units and purchase price of units, sum of participant accounts equal fund asset value. (only applicable for DC)

Note: The probability and impact will vary depending on the organization/business unit that is being audited.

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 1. Separation of Duties and Authorizations

Objective:
Are separation of duties (SOD) controls in place which allow only authorized cash movements within and outside of the Pension Fund to be processed?

Risk/Exposure:
Failure to maintain an adequate separation of duties could result in the loss of cash and assets through fraud or mismanagement.

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 1. Separation of Duties and Authorizations
Primary Test: Separation of Duties (SD001.P)

Objective:
To ensure proper separation of duties exists so that no individual can control Pension fund activities within a process in order to misuse or divert company funds without detection. Essentially, one individual should not be permitted to perform activities which combine set up, approval, and/or reconciliation of benefit payments or contributions for defined contribution plans.

Approach:

- Review delegation of duties document and establish responsibilities of various committees and board. Determine which have a fiduciary responsibility and ascertain how powers are delegated from the fiduciary.

- Request the Organization's separation of duties assessment. Any individual with capabilities which would allow them to circumvent controls in the process should be identified and included in test samples.

- System access control review should be based on the SOD assessment as well.

- Does the assessment contain all duties which are performed in the function? Were all conflicts identified in the assessment?

- Specifically review check signatories and the individuals who have access to cash, handle blank and signed checks, perform bank reconciliations, write journal entries, approve movement of funds, and are involved in any payments or receipts operations.

- Was there adequate periodic review of job responsibilities and were the results documented?

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 2. Cash Controls

Objective:
Are ledger and cash controls in place to assure only authorized expense payments, benefit and contribution payments, and cash transfers within and outside of the fund are processed?

Risk/Exposure:
Cash and asset movements that are not properly authorized could result in misdirection or misappropriation of fund resources.

Employee pension payments are not calculated and executed according to plan documents.

The employees' individual participant accounts are not correctly valued.

The Human Resources (HR) assumptions associated with net periodic pension cost (NPPC) are not accurate and not appropriately communicated to the actuary.

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 2. Cash Controls
Primary Test: Cash Account Reconciliations (CC001.P)

Objective:
Are ledger and cash controls in place to assure only authorized cash movements within and outside of the fund are processed accurately?

Approach:
Review the process for reconciling recorded ledger cash transactions to source documentation and system feeds.

Review the process for reconciling the contribution payments (DC Plans) that are completed into the fund. Select a sample of the payment reconciliations and validate that the reconciliations are prepared accurately, reviewed and approved, and all reconciling items are aged and resolved promptly. Validate that the reconciliations are accurately reported in monthly management measurement or key indicator reports.

Review the process for reconciling the withdrawals from the fund (DC Plans). Select a sample of the withdrawal reconciliations and validate that the reconciliations are prepared accurately, reviewed, and approved, and all reconciling items are aged and resolved promptly. Validate that the reconciliations are accurately reported in monthly management measurement or key indicator reports.
Review the process for reconciling the participant payments (DB Plans) that are completed to the beneficiaries. Select a sample of the payment reconciliations and validate that the reconciliations are prepared accurately, reviewed, and approved, and all reconciling items are aged and resolved promptly. Validate that the reconciliations are accurately reported in monthly management measurement or key indicator reports.

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 2. Cash Controls
Primary Test: Recipient Eligibility and Payments (CC002.P)

Note: Related to Defined Benefit Plans

Objective:
To verify that all participants and recipients entitled to participation in Pension Management funds are receiving proper valuation for their entitlements and proper payout of benefits.

Approach:
Identify all types of eligible recipients who are authorized to receive payments for IBM Defined Benefit Plans (e.g., IBM pensioners, IBM employees' part of a divestiture, surviving spouses, widows, orphans, etc.)

Eligibility
Obtain a list of all current recipients for the audit time period. Select a sample of recipients, including each type of recipient in the sample, and test the following:

- All current benefit recipients are valid current, former IBM employees, participants of the Global IBMer program, or divested employees and entitled to payments. In case of a surviving spouse, confirm valid spousal relationship (e.g., not divorced) and entitlement to payment. This may include checking terms/conditions associated with re-married status. For orphans' pensions, this may include proof of relationship. For pensioners who have moved out of the country, there may be requirements to provide a "proof of life" at specific intervals for the payments to continue.

- What steps does the fund take to ensure recipients are still eligible? What documentation is required from the payment recipients by the plan or per local law to prove eligibility?

- Do duplicate or nonexistent social security records (or equivalent) exist? How often are records tested for incorrect or fraudulent records? This can be checked using the HR system, pension system, or census data, if applicable.
- Request information surrounding all divestitures that have accrued where the pension assets and/or the pension obligation have transferred to the acquiring company. Should those employees continue to receive benefits from IBM? If not, request supporting documentation that the benefit payment stopped.

Obtain a list of all separations that occurred during the audit period that includes all relevant service dates to the pension plan. Review the list and select a sample of recipients and test the following:

- For employees that met benefit payment eligibility for the plan, validate that the required pension benefit was completed.

- For employees that were plan eligible, but benefit payouts were deferred until a future date, validate that the deferred employees were tracked and managed until the benefits were owed and paid.

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 2. Cash Controls
Primary Test: Recipient Eligibility and Payments (CC002.P)
(Continued)

Benefit Calculations and Payments Testing

- Verify the accuracy of the benefit calculations based on employee data, election, plan requirements, and actuarial input. (only applicable for DB)

- Determine whether country laws regulate the total amount of pension benefits to be capped, and test to ensure no employees have exceeded this limit. Also, review laws for minimum payments requirements based on age.

- Are payment amounts correct? Check salary history against payment terms and conditions based on retirement date and applicable retirement program in effect on that date.

- If applicable, have cost of living adjustments been correctly reflected in the payment system? (only applicable for DB)
- Validate all required approvals were complete for all final calculations, including business as usual (BAU), manual calculations, and lump sums over the clip levels. (only applicable for DB)
- Are payments being made timely and approved per the plan delegations for withdrawals?
- Verify and validate the process in place to identify and track incorrect payments. (only applicable for DB)

- Specifically for Global IBMers (GI) review the following for eligibility:
    - For the GI Assignment plan: Global IBMer Assignees who are Defined Contribution (DC) Plan or Cash Balance (DB) Plan members are not allowed to maintain their home country pension plan nor enroll in destination country pension. These employees are to be provided with a cash allowance in the destination country based on the value of the lost IBM home country pension contributions. Global IBMer Assignees who are Defined Benefit (DB) Plan members will continue to participate in the home country plan based on imputed earnings where legally possible and will not enroll in their destination country pension plan. There are certain scenarios where the above policy cannot be followed due to legal reasons. We have an agreed process with Benefits for these cases.

    - For the GI Accommodation plan: Participation in the home country pension plan must cease, and there will not be any compensation for any loss of home country pension benefits. Employees will be eligible for pension benefits in the destination country ONLY if all other Fixed Term Hires (FTH) are normally eligible for those benefits. If a pension benefit is normally provided to FTH employees, then a cash allowance will be provided to the Global IBMer assignee in the destination country for the value of the IBM destination country pension contribution. If a pension benefit is not normally provided, then the Global IBMer assignee will not receive any cash allowance, even if regular employees in the destination country normally receive a benefit.

      Select a sample of payees and compare the HR record data to the data provided to the actuary to ensure the assumptions match and the payment properly calculated based on those assumptions.

- Review the process for communicating and resolving any appeals for payout calculations. How clear are the communications for how a claimant can file and escalate their appeals if they are disputing the payout calculation? Evaluate the adequacy of aging and reporting of appeals.

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 2. Cash Controls
Primary Test: Contributions and Matching (CC003.P)

Note: Defined Contribution Plans and Defined Benefits Plans

Objective:
To validate that correct employer contributions were made in accordance with established plan guidelines. (Some DB plans may also require contribution payments from active participants)

Approach:
For IBM contributions, review the IBM contribution/matching rules and process used for determining company matching and test the following:

- Was the participant eligible for company matching? Was the correct percentage matched based on the plan?
- Was the correct contribution amount made by IBM per plan guidelines?
- If an employee separates, what is the process to ensure contributions are stopped? How are the funds returned to IBM if there is a timing issue or vesting requirements were not met?

For employee contributions, review the contribution rules and process to manage employee contributions. Test the following:

- How are ineligible employees prevented from making contributions?
- How is eligibility determined? How are employees notified?
- If the country requires participation, how is it validated that all eligible employees are participating?
- If there are limits in place related to how much the employee can contribute, how are those tracked and managed?
- How are employee contribution election requests entered? If not automated, is there a process to reconcile the contribution amount from the employee request to the amount entered in the system?
- Are employee contribution changes handled in a timely manner?

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 2. Cash Controls
Primary Test: Asset Valuation (CC004.P)

Note: Defined Contribution Plans

Objective:
To access accuracy of assets at an employee and fund level.

Approach:
Review the process for valuing a participants' account. Determine the controls in place for flowing contributions into a participants' selected funds. Review the process for assigning the fund's gain/losses and application of the fund's Net Asset Valuation (NAV) for unit determination.

Determine if a process was in place to periodically review and validate the plan participants' account valuations? Was management knowledgeable of the valuation process?

Select samples at the employee level from Custodian/ Record keeper to assess the asset values are accurate for each employee record.

- Assess if the total assets were assigned to the fund correctly based on the investment.
- Verify employee and employer contribution amounts were accurate within their funds.
- Validate the unit value assigned to the fund was accurate and based on the fund NAV.
- Validate the unit purchase price and number of units purchased was accurate at the participant level.
- Check that the sum of participant account values equals the total fund value.

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 2. Cash Controls
Primary Test: Participant Withdrawals and Loans (CC005.P)

Note: Defined Contribution Plans

Objective:
To validate that participant withdrawals and loans are handled in a manner compliant with government and plan guidelines.

Approach:
Obtain a list of all participant loans and withdrawals and test the following:

<u>Loans</u>

- Were loans properly requested and reviewed?
- Were loan payments for the correct amount? Was the loan amount within guidelines, i.e., did not exceed the employee contribution amount?
- Were the loan repayment terms elected by the participant correctly established in the system?
- Is there a process in place to monitor repayment and notify recipients of potential actions that could happen due to non-payment?
- Are defaulted loans flagged as such? Is the participant taxed accordingly?

<u>Withdrawals</u>

- Are withdrawals allowed by the plan guidelines?
- Are there any governmental requirements that must be met?
- Was the withdrawal request documented sufficiently to provide reasonable assurance as to the reason for the withdrawal?
- Were any vesting requirements considered for the determination of the withdrawal amount?
- Is there evidence of review by the plan sponsor or outsourced vendor? Was a reasonable effort made to clarify any unclear or missing documentation?
- If the withdrawal was not one of the established, pre-defined acceptable reasons, what review was performed to determine eligibility for the payment? Was IBM HR or IBM Legal involved?
- If there are any penalties or taxes required to be withheld, was there evidence of this being performed?
- If the plan requires non-participation or any other subsequent actions to take place following a withdrawal, is there evidence of these actions being performed?

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 2. Cash Controls
Secondary Test: Employee Rollovers Into or Out of the Fund (CC006.S)

Objective:
To validate that rollover transactions are processed accurately and in accordance with plan and regulatory requirements, regardless of rollover destination.

Approach:
Obtain a list of all employee rollovers into or out of the fund and test the following:

Transfers Out
- Is there written evidence permitted rollover destination (e.g., IRA, external provider, employer plan)?
- Was the permitted rollover amount correct?
- Was the employee account at IBM closed in a timely manner?
- Is there evidence that amount was disbursed to the new employer?

Note: Rollovers may be partial and do not necessarily require closure of a participant account.

Transfers In
- Is there written evidence of amount rolled over to IBM from the former employer (e.g., letter to employee or IBM)?
- Evidence that amount was received by IBM?
- Can it be demonstrated that a new account has been opened for the new employee with an amount equal to transfer value?

Note: This test can be applicable to defined benefit and defined contribution audits depending on local country rules.

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 3. Fees and Contract Administration

Objective:
Are contracts for vendors, including banks, properly negotiated, selected, accounted for, and monitored? Are total fees and expenses reasonable, properly accounted for, and adequately managed?

Risk/Exposure:
Contracts that are improperly bid, negotiated, or selected could result in IBM not receiving the best value. Improper management of contracts could lead to cost overruns, improper accounting treatment or reporting, and continued selection of vendors which do not provide best value to IBM. Additionally, contracts which do not protect the interest of both IBM and its current and former employees could lead to additional financial cost due to possible litigation.

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 3. Fees and Contract Administration
Primary Test: Fees and Expenses (FC001.P)

Objective:
To ensure Pension Benefit related expenses are reasonable, contain supporting documentation, comprehensively and completely identified, and reviewed by management.

Approach:
- Determine if fees and expenses are reviewed at a detailed enough level to contain or manage costs. Can the total population of all fees and expenses be identified?

- Review the prior year and current year budget. Determine if it was adequately reviewed and approved by the country management and the Retirement Fund Board (RFB). Was the budget year-to-year monitored and reconciled for differences?

- Confirm that a monthly analysis of total fees and expenses is made by management. The review should include a year-to-year comparison and an actual to budget comparison.
- Review accounting treatment of all fees and expenses. Verify that expenses are classified correctly and have been recorded in the appropriate time period.

- Review adequacy of disbursement controls for the following:
    - Are appropriate payment authorization guidelines in place, and are they being followed?
    - Are separation of duties over accepting, paying and recording of fees adequate?
    - Are invoices received for payment reviewed for content, accuracy and supporting documentation?
    - Do billings conform to contractual requirements for services to be performed, and are they in accordance with billing terms?
    - Are invoices paid timely?

- Are all disbursements made through one control account for visibility and control? If not, are all disbursement accounts utilized by fund administrators for valid business reasons? Were all disbursements properly authorized?

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 3. Fees and Contract Administration
Secondary Test: Contract Administration (FC002.S)

Objective:
Validate if contracts for vendors, including banks, were properly negotiated, selected, accounted for, and monitored.

Approach:
Confirm that procedures governing procurement activities exist. If a procurement delegation is in place, ensure the department adheres to the Blue Book guidelines. If a delegation does not exist, ensure that Procurement is involved in the contract process. Request and review relevant SOC 1 reports (or equivalent assurance reports, including AAF reports (Assurance reports on internal controls of service organizations) where applicable) provided by vendors.

- Were contracts approved by the procurement organization, or, if purchasing responsibilities have been delegated, are controls in place at the delegated location? Is this delegation in writing and current (within the last twelve months)?
- Was there a reasonable basis for vendor selection? What controls are in place to ensure competent vendors are selected for high skill areas. If exceptional (single or sole) sourcing of a contract is used, is there a valid business justification with adequate management review and approval? Are these vendors re-evaluated annually?
- Are signed contracts on file and available for review?
- Were any payments made to the vendor prior to the final contract?
- Was a Legal review of the contract performed?
- Do contracts include all necessary clauses to protect both IBM and its current and former employees?
- Do the contracts sufficiently define scope of work and service levels to perform the required functions?
- Was a monitoring process in place to review vendor execution of contracted activities?
- For larger contracts, do audit clauses exist that allow further review of contracted processes?
- For larger contracts (assets over $100M), do contracts require that the vendors provide an ISAE3402/SSAE16. If an ISAE3402/SSAE16 is contractually required, review the following:
    - Was an assessment of the ISAE3402/SSAE16 performed?
    - Were there any material control weakness reported in the vendor's process?
    - Was an assessment of the user considerations performed? (i.e., actions required by IBM in order to ensure contract services)

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 4. Net Periodic Pension Cost Assumptions (only applicable for DB)

Objective:
To ensure that reporting of pension cost is correctly calculated and included in the ledger accurately.

Risk/Exposure:
Inaccurate transfer of information to actuaries and calculation of net periodic pension cost could result in inaccurate financial statement reporting.

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 4. Net Periodic Pension Cost Assumptions
Primary Test: Human Resources NPPC Assumptions (HR001.P)

Objective:
Verify that Human Resources (HR) assumptions for net periodic pension costs (NPPC) have been accurately communicated to the actuary. In addition, verify that the plan parameters, participant information, participant eligibility, and benefit payment information have been accurately reported to the actuary.

Approach:
- Review the HR assumptions used to calculate NPPC to ensure they have been appropriately approved and accurately communicated to the actuary. The calculation supporting the NPPC is performed annually at the end of the year by an independent actuary and submitted to CHQ Accounting. For benefit management audits, we will review that HR related data has been accurately reported to the actuary.

- Ensure that the actuary receives accurate details regarding employee information from local HR (i.e., salary, date hired, plan type, age, etc.).

Select a sample of plan participants and verify the actuary has the same details for the following:

- Participant salary details used for pension analysis
- Annual participant pension benefit amount
- Participant age
- Participant retirement date
- Any other participant details used by the actuary

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 5. Balance Sheet Account Reconciliations

Objective:
Are all pension balance sheet accounts reconciled on a monthly basis with the appropriate level of formal management review and approval?
Are all of the pension balance sheet account reconciliation performed in accordance with the Worldwide guidelines?

Risk/Exposure:
Correct and timely performance of reconciliations is a primary control to identify instances when defined processes are not functioning as intended. Failure to perform reconciliations consistently indicates a lack of management focus on essential financial controls and could lead to undetected errors or irregularities. This could delay detection of process errors and financial losses, or in extreme cases lead to the misstatement of the company's financial reporting.

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 5. Balance Sheet Account
Primary Test: Account Analysis and Controls (BS001.P)

Objective:
Are all pension balance sheet accounts reconciled on a monthly basis with the appropriate level of formal management review and approval?

Are all pension balance sheet account reconciliation performed in accordance with the Worldwide Account Reconciliation guidelines?

Approach:
Based on a process review, a list of accounts, and pension account balances determine whether:

- A definition exists which specifies at which level (minor, sub minor, department, ledger reporting unit (LERU), etc.) account ownership is determined.
- Each account is assigned to an owning manager who is the control point for the account.
- Documented evidence exists that the accounts are reconciled and reviewed per the frequency assigned in Blackline.

Select a sample of accounts in Blackline in order to test the effectiveness of management control of the reconciliation activity. Based on an initial review of the ledger balances and the process, select accounts with exception activity such as:

- Unexpected credits/debits (i.e., liability account with a debit balance or unexplained debits in a liability account).
- Unexpected source of activity in account (expense account sources in a tax account or journal sources in a system clearing account).
- Unusual trends in account balances.
- Significant variations in account balances from month to month.
- Accrual accounts with unchanged balances.
- Write-off activity level which would indicate control weaknesses in the process.
- Manual entries used to reconcile control accounts in an automated process.
- Control accounts between ledger and subsidiary systems with aged variances.

For the accounts selected, determine:

- Was an effective process in place to ensure that the accounts were assigned to owning managers?
- Were reconciliations performed on a timely basis, signed and dated by the preparer, and approved by appropriate management?
- Were accounts reconciled and analyzed to appropriate auxiliary and source documents?
- Were reconciling items timely and accurately resolved?
- Was the status of reconciliations and the number of reconciling items accurately reflected in key indicator reports, if required?
- Were variances appropriately aged, and action plans with responsible parties identified included when necessary?

Determine whether new accounts that are created as a result of accounting changes, new divisions, subsidiaries, etc. are assigned to an owner.

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 6. Cybersecurity and Data Protection

Objective:
Does the process ensure that data privacy and protection requirements are in place and managed to meet IBM and regulatory requirements?

Risk/Exposure:
Insufficient physical and logical controls over data storage or transmission for payments, contributions or actuarial requirements could lead unauthorized access to sensitive personal information (SPI) or confidential information. Insufficient adherence to the GDPR or other regulatory data protection requirements could impact the IBM reputation and could result in legal violation.

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 6. Cybersecurity and Data Protection
Primary Test: Cybersecurity and Data Protection (CP001.P)

Objective:
This process involves access to and use of both personal information (PI) and sensitive personal information (SPI). Such information must be protected so that only the minimum amount of information necessary to execute the process is shared with those who perform the process. Determine whether process design and execution protect PI and SPI for pension benefit activities and met regulatory requirements. This would include data transfers both within IBM and between external suppliers.

Approach:
Consider ways that PI and SPI could be compromised.

Verify that accesses have been limited based on business need.

Evaluate security of communications and file transfers by checking that where applicable there was encryption, password protections, no passwords were included in the same communication with protected files, and there was a need to know for shared sensitive information.

Verify that data transmissions that include PI or SPI meet IBM and local regulatory requirements.

Assess the data shared for applicability with the European Union (EU) General Data Protection Regulation (GDPR).

Review contracts with suppliers and contractors for their methods on assuring data privacy. Validate whether IBM requires periodic reviews, such as SSAE16 and if IBM monitors supplier protection of data and compliance with regulatory requirements. Assess whether GDPR could apply to any of the information being provided and how the supplier complies with the regulations (note it is not necessary for the supplier to be in the EU for this to apply).

Test: Privacy

Objective:
Privacy laws impose requirements on how IBM and its Clients process PI. The Global Privacy Control Assessment Questions are composed with two key areas of the business to help address compliance with these various high-level laws.

- **IBM as a Controller** – The Enterprise Privacy Baseline – Controller establishes the high-level requirements that IBM must meet when acting as a Controller of PI. That is, PI that IBM collects and processes for its own purposes, such as Business Contact Information that IBM holds on its existing or potential customers or suppliers.

- **IBM as a Processor** – The Enterprise Privacy Baseline – Processor establishes the principles and requirements that IBM must meet when acting as a Processor of Client PI and applies to all products, offerings, and services (including their components) that IBM provides to Clients, regardless of whether IBM develops or re-brands them, or provides them for a fee or on a beta, trial, or no-charge basis.

CONTROL ASSESSMENT QUESTIONS
Key Control Question: 6. Cybersecurity and Data Protection
Primary Test: Cybersecurity and Data Protection (CP001.P)
(Continued)

Approach:
Review the Data Privacy responses provided from the Initial Data Request. Determine if IBM is Controller or Processor of PI/SPI data in the process.

Testing:

IBM as Controller
If IBM is Controller, request a risk-based sample of Global Privacy Assessments for the processes and/or assets. Complete the testing based on the latest CA&AS required data privacy education.

IBM as Processor
If IBM is Processor, select a sample of products/offerings/services provided for the in-scope activities. Complete the testing based on the latest CA&AS required data privacy education.

IBM as both Controller and Processor
Test either IBM as Controller or Processor, do not test both. Consider the volume and sensitivity of the controller and processor data and select the higher risk.